

OWASP tells you
what breaks.
Not who breaks it.

The gap

The framework names the risk —
the mechanism inside the system.

It doesn't name the scenario:
who trips the wire, or why.

We're missing the plain-language names.

The Disgruntled Employee: the AI risk OWASP doesn't name

The Disgruntled Employee

A valid login. A motive.
They loop the priciest calls —
or strip the rate limits they
were trusted to manage.

Denial of wallet — with a face.

Strip the motive

Take the motive away and the damage stays. The same bill lands when someone simply isn't thinking clearly.

No anger, no plan, same outcome.

The Disgruntled Employee: the AI risk OWASP doesn't name

The missing axis: intent

- **Malicious**

meant to hurt you

- **Negligent**

knew better, cut the corner

- **Ignorant**

had no idea

Same risk. Different people,
different controls, conversations.

The Disgruntled Employee: the AI risk OWASP doesn't name

Beyond the Top 10

Some failures don't map at all
— shadow AI, or over-reliance
on an agent that's confidently
wrong.

Governance gaps, not system flaws.

The Disgruntled Employee: the AI risk OWASP doesn't name

Your turn

What's a scenario
the framework doesn't
have a name for?

Drop it in the comments.

The Disgruntled Employee: the AI risk OWASP doesn't name